Proteção de um Galaxy S23 Ultra Comprometido — Ações Assume-Breach Antes da Reestruturação da LAN

> **Documento complementar** ao plano Zero-Trust (V14). Não repete o que já está coberto em `ZeroTrust_Setup_Caseiro_Checklist_V14.md` e seu `Anexo-A`. Foco: detecção, coleta de evidências e endurecimento do **endpoint móvel** antes da reconstrução da LAN.
> **Modelo de ameaça:** assuma que o aparelho já está comprometido e que o atacante pode ter certo nível de controle. Trate qualquer ferramenta executada *no próprio celular* como uma pista, nunca como prova.

Princípio central

No Android você tem **menos** liberdade no dispositivo do que no Windows — não há shell de administrador, nem agente de kernel, nem como instalar seu próprio driver de EDR. Isso corta para os dois lados: você não consegue inspecionar o SO em profundidade, mas o atacante (a menos que tenha um exploit de root completo / implante classe Pegasus) também não faz tudo o que quer, porque o sandbox do SO limita os apps.

Consequência prática: a camada de detecção autoritativa precisa ficar **fora do aparelho, na rede** — exatamente como no notebook. O trabalho do sensor de rede serve para os dois.

Verdade desconfortável da perícia forense: exploits *zero-click* que vivem apenas na RAM volátil (classe Pegasus) não deixam rastros persistentes, somem ao reiniciar e exigem análise de memória ou de tráfego de rede; implantes em *baseband*/modem rodam abaixo do SO e nenhuma ferramenta em nível de aplicativo os enxerga. **Uma varredura limpa nunca prova que o aparelho está limpo** — apenas descarta o que é comum e barulhento (stalkerware, APKs maliciosos).

TL;DR — ordem de prioridade

1. **Sensor de rede fora de banda** (TinyCheck / SpyGuard no mesmo Pi/N100 do notebook) — maior valor, o atacante no celular não o enxerga.
2. **Coletar evidências agora** (AndroidQF + MVT em um computador confiável, capturas de tela de apps com Acessibilidade / admin de dispositivo) **antes** de resetar qualquer coisa.
3. **Ligar Advanced Protection + Intrusion Logging** (Android 16 — você tem) para começar a acumular logs criptografados e à prova de adulteração.
4. **Endurecer agora** (Auto Blocker no máximo, Play Protect, revisar permissões perigosas).
5. **Remediação real = reset de fábrica / aparelho novo**, sequenciado **junto/depois** da reconstrução da LAN, nunca antes.

Custo: praticamente tudo é gratuito/open-source e reaproveita o hardware do sensor do notebook.

Camada 1 — Detecção de rede fora de banda (maior valor)

Esta é a melhor jogada e reaproveita o hardware do estudo do notebook.

TinyCheck (Kaspersky — gratuito, open-source)

Feito exatamente para este cenário. É instalado em um dispositivo separado (Raspberry Pi), **não no celular**, atuando como intermediário entre o roteador e o aparelho Wi-Fi — assim qualquer spyware no celular não enxerga o monitoramento. Todo o tráfego passa pelo TinyCheck, que analisa em tempo real e avisa se o celular envia dados a um servidor de spyware conhecido. Você conecta o celular a uma rede Wi-Fi transitória que ele cria, ele captura as comunicações e mostra um relatório em menos de um minuto. **Detecta sem alertar o perpetrador** de que uma verificação está acontecendo — importante se você suspeita que alguém monitora suas contramedidas.

SpyGuard (fork mantido, foco em detecção de ameaças)

Fork do TinyCheck mais ativamente desenvolvido; a Coalition Against Stalkerware hoje aponta para o SpyGuard como sucessor. Prefira-o ao TinyCheck "puro" se quiser IOCs mais atualizados.

Limites honestos

A Kaspersky alerta que o TinyCheck **não** garante detecção completa de todo stalkerware — um resultado "nada detectado" **não exclui** comprometimento. Ele pega tráfego para infraestrutura *conhecida* como maliciosa; C2 sob medida em domínios limpos pode escapar. Por isso é uma camada, não a resposta inteira.

Hardware

O mesmo mini-PC Intel N100 ou Raspberry Pi 4/5 do estudo do notebook roda TinyCheck/SpyGuard. O setup documentado: Raspberry Pi 3 ou superior com duas interfaces Wi-Fi (uma para internet, outra como AP para o celular) **ou** uma Wi-Fi + Ethernet. Se você construir o sensor Suricata/Zeek do notebook, aponte o Wi-Fi do celular por ele também — a detecção de IOC/C2 do Suricata vale igualmente para o celular.

Cuidado obrigatório

Se o celular já está comprometido, conectá-lo à sua LAN **atual** (também suspeita) para testar é aceitável para análise de tráfego, mas **não** se autentique em contas sensíveis durante isso. O AP transitório do TinyCheck evita tocar na sua rede principal — prefira essa opção.

Camada 2 — Coleta forense no dispositivo (evidências, enquanto o aparelho comprometido ainda existe)

MVT (Mobile Verification Toolkit — Amnesty International, gratuito)

A ferramenta forense séria. **Mudança importante (2026):** a análise direta por ADB foi **removida**; agora você coleta artefatos com **AndroidQF** e depois analisa com `mvt-android check-androidqf`.

Fluxo em um **computador confiável separado** (sua máquina de dev, não o celular):

1. Habilite Depuração USB no celular, conecte via USB.
2. Rode **AndroidQF** para coletar bug report, logs de sistema, pacotes instalados e um backup de SMS.
3. `mvt-android download-iocs` — baixe os indicadores mais recentes primeiro.
4. `mvt-android check-androidqf <output>` — compara tudo contra feeds de IOC STIX2 (Pegasus, Predator, famílias de stalkerware) e sinaliza rastros maliciosos com linha do tempo cronológica.

Expectativa correta: o MVT é destinado a usuários técnicos com experiência forense e **não** é uma ferramenta de autoavaliação casual. Como desenvolvedor aprendendo Python, você consegue rodá-lo (`pip install mvt`, Python, scriptável), mas leia a saída criticamente. O MVT também avalia apps instalados contra o **VirusTotal**, integrando-se às APIs de threat-intel do estudo do notebook.

Grande trunfo do seu aparelho — Android 16

Como o S23 Ultra está em One UI 8 / Android 16 (8.5 se atualizado), você pode habilitar **Advanced Protection + Intrusion Logging**. Quando ativado, o Android cria logs estruturados e criptografados de consultas DNS, conexões de rede de saída, inícios de processo, atividade ADB e outros eventos de segurança, armazenados criptografados na conta Google, com a chave protegida pelo PIN do dispositivo — **inacessíveis até para o Google**. É um "gravador de voo" no dispositivo, de alta fidelidade e resistente a adulteração, que complementa a aquisição do AndroidQF. **Ligue agora** para começar a acumular evidências.

Triagem manual rápida (minutos, sem ferramentas)

- **Configurações → Acessibilidade** → revise todo app com acesso. Acessibilidade permite que um app aja como você, leia outros apps e altere configurações — é uma das permissões mais perigosas do Android e favorita de spyware. Não conceda a nada, exceto talvez um AV confiável.
- **Configurações → Segurança → Apps de administração do dispositivo** — remova o que não reconhecer.
- **Gerenciador de permissões** → revise Câmera, Microfone, Localização, SMS, "Sobrepor a outros apps" e "Instalar apps desconhecidos" — revogue de qualquer coisa

inesperada.
- Códigos de discador (`*#*#001#*#*` etc.) são remédio popular e **não confiável** no One UI moderno; não dependa disso. Use a revisão de permissões/admin/acessibilidade.

Camada 3 — Scanners no dispositivo (apenas segunda opinião, dentro da fronteira de confiança)

Rodam como apps em sandbox, então um implante profundo pode se esconder deles — trate resultados como pistas.

- **Malwarebytes for Android** — você já tem a licença Windows; o app móvel é um scanner razoável de stalkerware/PUA. No teste de stalkerware da AV-Comparatives (2025), apps de segurança mainstream detectam boa parte do stalkerware de prateleira, mas a rotulagem costuma ser genérica ("ameaça detectada") em vez de específica.
- **Protectstar Anti Spy / Bitdefender Mobile Security / Kaspersky** — basta **um** scanner reputado; não empilhe três.
- **Manual do atacante (AV-Comparatives):** o stalkerware é tipicamente *sideloaded* com "instalar apps desconhecidos" ligado, frequentemente com direitos de administrador de dispositivo concedidos e o ícone oculto, e alguns fornecedores orientam a vítima a **desligar o Play Protect**. Portanto: **reative o Play Protect**, e cace especificamente apps de **ícone oculto** (Configurações → Apps → mostrar sistema/todos) e **admins de dispositivo** inesperados.

Camada 4 — Reduzir a superfície de ataque AGORA (Samsung, gratuito, nativo)

Seu S23 Ultra tem proteções que a maioria dos aparelhos não tem — ligue todas antes da reconstrução:

- **Auto Blocker** (Configurações → Segurança e privacidade → Auto Blocker). Recurso abrangente do One UI 6+ que previne acesso não autorizado, instalação de malware por sideloading e outras ameaças. Bloqueia apps de lojas não autorizadas, **bloqueia comandos enviados via USB** e bloqueia sideloading malicioso. Coloque no **máximo** se houver a opção. O bloqueio de comandos USB é especialmente relevante sob assume-breach (derrota *juice-jacking* / cabo malicioso).
- **Android Advanced Protection Mode** (Android 16). Pacote de endurecimento em um interruptor — desabilita caminhos de sideloading, força Navegação Segura, endurece contra ataques de *downgrade*, ativa Intrusion Logging. Tradeoff: agrupa mitigações e pode interferir no Android Auto — mas para postura assume-breach vale a pena.
- **Maintenance Mode** — cria uma conta de usuário separada que bloqueia acesso a fotos, mensagens, contatos e apps. Se precisar entregar o aparelho a alguém

(assistência, inspeção), use para que não alcancem seus dados.

- **Mantenha o patch em dia:** você recebe atualizações ativas — o patch de março/2026 sozinho corrigiu 65 falhas. Instale toda atualização imediatamente; um atacante que depende de um exploit corrigido perde o acesso.

Camada 5 — A única remediação real (sequencie com a reconstrução da LAN)

Como no Windows, reset é a única correção verdadeira, e a prática forense é direta: se um celular está comprometido com stalkerware, a opção mais segura é **um aparelho novo em uma conta nova; não** restaure a partir de um backup do dispositivo comprometido, pois configurações de stalkerware ou configs comprometidas podem migrar — configure do zero com contas e senhas novas. Se a remoção falhar ou o comprometimento parecer profundo (processos ocultos, root), faça backup dos dados essenciais e **reset de fábrica**.

Árvore de decisão prática

1. **Stalkerware comum / APK malicioso encontrado** (caso mais provável): **reset de fábrica** do S23 Ultra basta. Após o reset, configure com **conta Samsung + Google novas**, restaure **apenas dados** (fotos/contatos/arquivos, escaneados antes no sensor/VM), nunca reinstale o app suspeito, nunca restaure backup cego de app+configurações.
2. **Suspeita de implante em nível de root ou classe Pegasus** (raro; indícios: MVT sinaliza, TinyCheck mostra C2 para infra de spyware conhecida, reinfecção persistente após reset): o reset limpa implantes só-em-RAM ao reiniciar, mas um **aparelho novo** é a escolha conservadora. Não vincule o novo aparelho a números/e-mails de recuperação antigos.
3. **Preocupação com firmware/baseband:** não corrigível por reset — **troque o aparelho**. Não persiga isso sem evidência concreta.

Sequenciamento crítico com seu trabalho de LAN Zero-Trust

Preserve evidências primeiro (aquisição AndroidQF + relatório TinyCheck + capturas de tela de apps admin/acessibilidade) **antes** de resetar, pois o reset destrói tudo isso. Depois, a ordem é:

```
construir o sensor confiável
        ↓
analisar o celular fora de banda
        ↓
endurecer configurações (Auto Blocker, Advanced Protection)
        ↓
reconstruir a LAN  ← (seu plano V14)
        ↓
reset de fábrica / trocar o celular + reinscrever na rede LIMPA com contas
novas
```

Reconectar um celular recém-resetado a uma LAN ainda comprometida arrisca recomprometimento imediato, então o reset do celular deve acontecer **depois/junto** da reconstrução da LAN, **nunca antes**.

Integração com o stack existente

- O **sensor N100/Pi** do estudo do notebook roda TinyCheck/SpyGuard sem hardware extra.
- As **APIs VirusTotal** / **AbuseIPDB** / **Shodan** e os **servidores MCP** configurados para o notebook enriquecem diretamente a saída do MVT (hashes de apps, IPs de C2) — boa prática de automação em Python rumo ao seu objetivo de engenharia de IA.
- **Suricata**/**Zeek** no sensor monitoram o tráfego do celular com as mesmas regras — nada novo a construir para o móvel além de apontar o celular por ele.

Tabela resumo de ferramentas

Ferramenta	Onde roda	Custo	Fora de banda?	API/scriptável	Papel
TinyCheck / SpyGuard	Pi/N100 separado	Grátis	**Sim**	Python	Detecção de C2/exfiltração em tempo real
MVT + AndroidQF	PC confiável	Grátis	Aquisição offline	Python (`pip install mvt`)	Perícia / IOCs Pegasus/stalkerware
Advanced Protection + Intrusion Logging	No aparelho	Grátis	Logs cripto resistentes	—	"Gravador de voo" de eventos de segurança

Ferramenta	Onde roda	Custo	Fora de banda?	API/scriptável	Papel
Auto Blocker (máx.)	No aparelho	Grátis	Não	—	Bloqueia sideloading + comandos USB
Play Protect (reativar)	No aparelho	Grátis	Não	—	Varredura de apps Google
Malwarebytes / Bitdefender / Kaspersky	No aparelho	Grátis/pago	Não	—	Segunda opinião (apenas pistas)
Maintenance Mode	No aparelho	Grátis	Não	—	Proteger dados ao entregar o aparelho

---

Dois avisos a manter em mente

1. **Toda ferramenta no celular está dentro do alcance possível do atacante.** TinyCheck/SpyGuard no dispositivo separado e os Intrusion Logs criptografados são seus sinais mais confiáveis; os scanners de app são os menos confiáveis.
2. **Isto é orientação de detecção e endurecimento, não garantia de remoção.** Se os achados apontarem para spyware direcionado/de nível estatal, ou se houver perigo pessoal real, o caminho certo é **perícia digital profissional**, não DIY — um passo errado pode alertar quem estiver observando.

Documento gerado como complemento ao plano Zero-Trust V14. Reaproveita o sensor de rede (Intel N100 / Raspberry Pi) e as APIs/MCP de threat-intel já definidos para o endpoint Windows.